

Procedimientos de detención

1. Intrusión Inicial

Qué sucede: El atacante busca una debilidad. Puede ser un Exploit Phishing o Brute Force

Procedimiento típico: Instalación que le permite al atacante manejar la computadora infectada de forma remota.

2. Movimiento Lateral

El atacante ya está dentro, pero en una computadora sin importancia ahora busca el premio mayor

Qué sucede: Escanea la red interna para ver qué otros servidores hay. Intenta robar credenciales de administradores que estén guardadas en la memoria

Procedimiento típico: Salta de la PC de un empleado al servidor de archivos, y de ahí al Controlador de Dominio

3. Inicio de Cifrado (El Ataque Activo)

Aquí es donde el malware empieza a destruir la disponibilidad de los datos.

Qué sucede: El ransomware recorre los discos duros y carpetas compartidas. Utiliza algoritmos matemáticos para bloquear los archivos.

Procedimiento típico: El malware primero elimina las Shadow Copies para que no puedas restaurar los archivos fácilmente, y luego empieza a cambiar las extensiones

4. Nota de Rescate (La Extorsión)

Qué sucede: Al terminar el cifrado, el virus cambia el fondo de pantalla o crea archivos en todas las carpetas.

Procedimiento típico: Proporciona una dirección de la Dark Web y un código de identificación único para que la empresa entre a negociar el pago en Bitcoin.

5. Detección Temprana SOC (La Alarma)

Es el punto donde la tecnología de defensa identifica que algo no es normal.

Qué sucede: Las herramientas disparan una alerta roja. Por ejemplo: Se detectaron 1,000 cambios de nombre de archivos en 10 segundos o Un usuario de contabilidad está intentando entrar al servidor de ingeniería.

Procedimiento típico: El analista del SOC valida la alerta y declara un Incidente de Seguridad.

6. Activación Playbook (La Respuesta)

Se deja de investigar y se empieza a actuar bajo un protocolo estricto.

Qué sucede: Se ejecutan acciones automáticas o manuales para detener el avance. No se improvisa; se sigue la lista de pasos que definimos antes.

Procedimiento típico: Bloqueo de puertos, aislamiento de hosts infectados y revocación de certificados digitales comprometidos.

7. Key Event (Punto de Inflexión)

Es un momento decisivo durante la crisis que cambia el rumbo del ataque.

Qué sucede: Puede ser la identificación del o el bloqueo del servidor de comando del atacante

Procedimiento típico: El equipo de crisis toma la decisión de desconectar el internet de toda la empresa o apagar el servidor principal para evitar que el cifrado continúe.

8. Impacto Reducido vs. Impacto Completo (Los Resultados)

impacto Reducido (Éxito):

Qué es: El ataque fue contenido en las primeras 2 o 3 computadoras.

Resultado: Solo se pierden unas horas de trabajo. La empresa sigue operando. El costo de limpieza es bajo.

Impacto Completo (Desastre):

Qué es: El atacante logró cifrar el 90% de los servidores y los respaldos.

Resultado: La empresa se detiene por días o semanas. Pérdida masiva de dinero, daño a la reputación y posible quiebra si no se pueden recuperar los datos.

Segunda imagen siem 1

Fase de Gestión de Datos (Ingesta)

Inicio / Recolección de eventos: El SIEM recibe registros de toda la empresa: firewalls, antivirus, servidores, correos y bases de datos es la materia prima de la seguridad.

Normalización: Como cada equipo habla un distinto, el SIEM traduce todos los logs a un formato estándar. Así, una alerta de un firewall Cisco y una de un servidor Windows se pueden comparar fácilmente.

Correlación (MITRE): El sistema busca patrones utiliza el marco MITRE ATT&CK para ver si varios eventos aislados forman en realidad un ataque complejo.

II. Fase de Evaluación y Triage

¿Actividad sospechosa?: Un motor de reglas decide si el patrón encontrado es peligroso.

Si no: El evento se guarda silenciosamente en la base de datos.

Si sí: Se procede a la siguiente etapa.

Generar alerta: Se creara un ticket o aviso en la consola del analista de seguridad.

Priorización: El sistema asigna urgencias no es lo mismo un intento de adivinar una contraseña (Baja) que la detección de un virus en el servidor principal (Crítica).

III. Fase de Análisis Humano (SOC L1)

Análisis SOC L1: Un analista de Nivel 1 revisa la alerta.

Mira el contexto: ¿Quién es el usuario? ¿Desde dónde se conectó? ¿Es un comportamiento normal para él?

¿Falso positivo?: El analista decide si la alerta es una amenaza real o un error del sistema

Si es Falso Positivo → Cerrar alerta: Se documenta por qué no era peligroso y se finaliza el proceso para no perder tiempo.

IV. Fase de Respuesta y Mejora

Clasificación del incidente: Si la amenaza es real, se etiqueta el tipo de ataque para aplicar la estrategia correcta.

Respuesta: Aquí es donde se ejecuta el Playbook que vimos anteriormente. Se bloquean IPs, se aíslan computadoras o se cierran cuentas de usuario.

Actualizar métricas : Se registran los tiempos de respuesta:

MTTD : ¿Cuánto tardamos en darnos cuenta?

MTTR : ¿Cuánto tardamos en solucionar el problema?

Fin: El incidente se cierra, los sistemas vuelven a la normalidad y la empresa está más segura.

Infraestructura Crítica

1. Sistema Eléctrico (Plantas UPS)

Procedimiento: Proporcionar energía de respaldo inmediata y a largo plazo
Importancia: Sin esto, el SOC queda ciego y los atacantes pueden aprovechar el apagón para entrar física o digitalmente.

2. Control de Acceso

Es la seguridad física conectada al suministro eléctrico.

Procedimiento: Gestión de cerraduras electrónicas, lectores de huellas o tarjetas para entrar al Data Center o a las oficinas del SOC.

Importancia: Evita que personas no autorizadas manipulen físicamente los servidores donde se guardan los logs o se ejecutan los playbooks.

3. Sistemas de Telecomunicaciones y Cableado Estructurado

Procedimiento: Organización y mantenimiento de cables de fibra óptica, racks y switches que conectan toda la red interna.

Importancia: Si el cableado falla o es sabotado, la Recolección de Eventos del SIEM se detiene por completo.

4. Monitoreo (Base de Datos Central)

Es el núcleo que recibe los Datos de Rendimiento de las telecomunicaciones.

Procedimiento: Supervisar constantemente que el hardware esté operando dentro de los niveles normales de temperatura, carga y tráfico.

Importancia: Permite detectar fallos técnicos antes de que se conviertan en incidentes de seguridad.

5. Sistemas de Enfriamiento (Aire Acondicionado Precisión)

Procedimiento: Mantener la temperatura y humedad óptimas para los servidores.

Importancia: El hardware de alta capacidad genera mucho calor. Un fallo aquí puede causar que los firewalls se apaguen por sobrecalentamiento, dejando a la empresa vulnerable.

6. Equipo Contra Incendios

Procedimiento: Sistemas de detección de humo y extinción de incendios

Importancia: Protege la inversión física y los datos contra desastres ambientales.

7. Servicio de Mantenimiento

Procedimiento: Revisiones preventivas y correctivas de todos los puntos anteriores.

Importancia: Es el soporte que asegura que la infraestructura crítica sea confiable 24/7. Un UPS sin mantenimiento no funcionará cuando más se necesite.